

Security Scan Report

Target: <https://juice-shop.herokuapp.com/#/>

Scan Date: July 24, 2026 at 05:50 UTC

Scan ID: 5abc807a-3526-4230-ab61-b2c4da8d65d2

0 CRITICAL

3 HIGH

4 MEDIUM

9 LOW

Executive Summary

Security scan of 'https://juice-shop.herokuapp.com/#!/' identified 18 raw findings, reduced to 16 unique issues after deduplication. ■ 3 HIGH-severity issue(s) should be prioritized for remediation within the next 48 hours. 4 MEDIUM-priority issue(s) should be addressed in the current development sprint. 9 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	18
After Deduplication	16
Critical Findings	0
High Findings	3
Medium Findings	4
Low Findings	9
Scan Duration	18.9s

Detailed Findings

[HIGH] #1: Missing Auth in admin:0

Risk Score	0.6839
Affected Location	https://juice-shop.herokuapp.com/admin:0
Vulnerability Type	MISSING_AUTH
CWE ID	CWE-306
Detected By	url-scanner

Explanation

This endpoint or function lacks authentication, allowing unauthenticated users to access protected resources. Found in admin. Admin panel may be accessible without proper authentication.

Code or HTTP Excerpt

```
1 | GET /admin → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 | ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 | ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Unauthenticated users could access the admin panel, potentially viewing or modifying sensitive data without authorization.

Fix Recommendation

Best Fix: Add authentication middleware or decorators to all sensitive endpoints. Verify user identity before serving protected data.

[HIGH] #2: Information Disclosure in .env:0

Risk Score	0.5335
Affected Location	https://juice-shop.herokuapp.com/.env:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in .env. Exposed.

Code or HTTP Excerpt

```
1 | GET /.env → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 | ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
```

```
5 | ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed API keys helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Block access to .env files in your web server config. In nginx: location ~ /\.env { deny all; }. In Apache: <FilesMatch "\.env"> Require all denied </FilesMatch>.

[MEDIUM] #3: Cors Misconfiguration in crossdomain.xml:0

Risk Score	0.4850
Affected Location	https://juice-shop.herokuapp.com/crossdomain.xml:0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation

The CORS policy is overly permissive, allowing unauthorized websites to make authenticated requests on behalf of users. Found in crossdomain.xml. crossdomain.

Code or HTTP Excerpt

```
1 | GET /crossdomain.xml → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 | ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 | ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

A malicious website could read API responses on behalf of authenticated users, potentially accessing sensitive data.

Fix Recommendation

Best Fix: Restrict Access-Control-Allow-Origin to specific trusted domains. Never combine wildcard origins with Allow-Credentials: true.

[MEDIUM] #4: Information Disclosure in config:0

Risk Score	0.4462
Affected Location	https://juice-shop.herokuapp.com/.git/config:0
Vulnerability Type	INFORMATION_DISCLOSURE

CWE ID	CWE-538
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in config. Exposed.

Code or HTTP Excerpt

```
1 | GET /.git/config → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed Git repository metadata and history helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Block access to .git/ directory in your web server config. In nginx: location ~ /\.git { deny all; }. Remove the .git directory from the deployed artifact.

[HIGH] #5: Information Disclosure in backup.sql:0

Risk Score	0.4462
Affected Location	https://juice-shop.herokuapp.com/backup.sql:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-530
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in backup.sql. Database backup file is publicly accessible — critical data exposure.

Code or HTTP Excerpt

```
1 | GET /backup.sql → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed the database helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove database backup files from the web root. Store backups in a non-web-accessible directory. Add rules to deny access to *.sql, *.bak, *.dump file extensions.

[MEDIUM] #6: Information Disclosure in :0

Risk Score	0.4220
Affected Location	https://juice-shop.herokuapp.com/wp-admin/:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in . WordPress admin panel is publicly accessible.

Code or HTTP Excerpt

```
1 | GET /wp-admin/ → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed the admin panel helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #7: Cors Misconfiguration in :0

Risk Score	0.3588
Affected Location	https://juice-shop.herokuapp.com/#!/:0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation

The CORS policy is overly permissive, allowing unauthorized websites to make authenticated requests on behalf of users. Found in . CORS allows all origins (*).

Code or HTTP Excerpt

```
1 | Access-Control-Allow-Origin: *
```

Business Impact

A malicious website could read API responses on behalf of authenticated users, potentially accessing sensitive data.

Fix Recommendation

Best Fix: Restrict Access-Control-Allow-Origin to specific trusted domains. Never combine wildcard origins with Allow-Credentials: true.

[LOW] #8: Information Disclosure in server-status:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/server-status:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in server-status. Apache server-status page is publicly accessible.

Code or HTTP Excerpt

```
1 | GET /server-status → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Suppress the Server header version information. In nginx: server_tokens off; In Apache: ServerTokens Prod. In Flask: remove or override the Server header.

[LOW] #9: Information Disclosure in phpinfo.php:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/phpinfo.php:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in phpinfo.php. PHP info page is publicly accessible — exposes server configuration details.

Code or HTTP Excerpt

```
1 | GET /phpinfo.php → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed configuration files helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Suppress the Server header version information. In nginx: server_tokens off; In Apache: ServerTokens Prod. In Flask: remove or override the Server header.

[LOW] #10: Information Disclosure in debug:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/debug:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-215
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in debug. Debug endpoint is publicly accessible — may expose sensitive application internals.

Code or HTTP Excerpt

```
1 | GET /debug → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed internal network services helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #11: Information Disclosure in sitemap.xml:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/sitemap.xml:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in sitemap.xml. sitemap.

Code or HTTP Excerpt

```
1 | GET /sitemap.xml → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed internal network services helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #12: Information Disclosure in actuator:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/actuator:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in actuator. Spring Boot Actuator endpoints are publicly accessible.

Code or HTTP Excerpt

```
1 | GET /actuator → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[MEDIUM] #13: Information Disclosure in robots.txt:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/robots.txt:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in robots.txt. robots.

Code or HTTP Excerpt

```
1 | GET /robots.txt → HTTP 200
2 | Content-Length: 28 bytes
3 | Preview: User-agent: *
4 | Disallow: /ftp
```

Business Impact

The disclosed user accounts and personal data helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Review robots.txt for sensitive path disclosure. While robots.txt is public, listing hidden paths like /admin or /backup reveals targets to attackers. Use authentication instead of obscurity.

[LOW] #14: Information Disclosure in .DS_Store:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/.DS_Store:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-538
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in .DS_Store. macOS.

Code or HTTP Excerpt

```
1 | GET /.DS_Store → HTTP 200
2 | Content-Length: 9903 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #15: Missing Security Header in :0

Risk Score	0.3168
Affected Location	https://juice-shop.herokuapp.com/#!/:0
Vulnerability Type	MISSING_SECURITY_HEADER
CWE ID	CWE-319
Detected By	url-scanner

Explanation

The server response is missing recommended HTTP security headers that instruct browsers to enable built-in protections. Found in . Missing HTTP Strict-Transport-Security (HSTS) header.

Code or HTTP Excerpt

```
1 | Response headers: Strict-Transport-Security = (not set)
```

Business Impact

Without this header, user accounts and personal data is more vulnerable to XSS, clickjacking, or MIME-type confusion attacks.

Fix Recommendation

Best Fix: Add Strict-Transport-Security: max-age=31536000; includeSubDomains to force HTTPS connections and prevent SSL stripping.

[LOW] #16: Information Disclosure in :0

Risk Score	0.2496
Affected Location	https://juice-shop.herokuapp.com/#!/:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in . Missing Referrer-Policy header.

Code or HTTP Excerpt

```
1 | Response headers: Referrer-Policy = (not set)
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

Appendix

Deduplication Statistics

Total raw findings: 18 | After deduplication: 16 | Reduction: 11%

Scan Metadata

Scan ID	5abc807a-3526-4230-ab61-b2c4da8d65d2
Target	https://juice-shop.herokuapp.com/##
Timestamp	2026-07-24T05:50:26.413606+00:00
Duration	18.9s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "fb9163ef-b58e-4b0d-a612-bdef0f460d9a",
    "title": "Missing Auth in admin:0",
    "file": "https://juice-shop.herokuapp.com/admin",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "MISSING_AUTH",
    "description": "Admin panel may be accessible without proper authentication.",
    "rule_id": "sensitive-path-admin",
    "confidence": 0.85,
    "cwe_id": "CWE-306",
    "cvss_score": null,
    "code_snippet": "GET /admin \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright (C) 2015-2016",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.6839,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "This endpoint or function lacks authentication, allowing unauthenticated users to access sensitive information.",
    "fix_suggestion": "",
    "business_impact": "Unauthenticated users could access the admin panel, potentially viewing or modifying sensitive data.",
    "raw": {
      "url": "https://juice-shop.herokuapp.com/admin",
      "status": 200,
      "path": "/admin"
    }
  },
  {
    "id": "b3669f84-ecc1-4093-a134-621958b6ad39",
    "title": "Information Disclosure in .env:0",
    "file": "https://juice-shop.herokuapp.com/.env",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "The .env file contains sensitive information that is exposed to the public.",
    "rule_id": "sensitive-file-disclosure",
    "confidence": 0.9,
    "cwe_id": "CWE-53",
    "cvss_score": 9.1,
    "code_snippet": ".env\n# Environment variables\nSECRET_KEY=your_secret_key_here\n# Database configuration\nDB_HOST=localhost\nDB_PORT=3306\nDB_NAME=juice-shop\nDB_USER=root\nDB_PASSWORD=root\n# API configuration\nAPI_KEY=your_api_key_here\n# JWT configuration\nJWT_SECRET=your_jwt_secret_here\nJWT_EXPIRATION=7d\n# Redis configuration\nREDIS_HOST=localhost\nREDIS_PORT=6379\nREDIS_PASSWORD=your_redis_password_here\n# Mail configuration\nMAIL_HOST=smtp.example.com\nMAIL_PORT=587\nMAIL_USERNAME=your_email@example.com\nMAIL_PASSWORD=your_email_password\nMAIL_DEFAULT_SENDER=your_email@example.com\n# Other configuration\nNODE_ENV=production\nLOG_LEVEL=info\nLOG_PATH=./logs\n# Security configuration\nCSP_SCRIPT_SRC='self'\n# Debug configuration\nDEBUG=false\n# Analytics configuration\nANALYTICS_ENABLED=false\n# Social media links\nGITHUB_URL=https://github.com/username/repo\nTWITTER_URL=https://twitter.com/username\n# Miscellaneous\nAPP_NAME=juice-shop\nAPP_VERSION=1.0.0\nAPP_AUTHOR=John Doe\nAPP_EMAIL=john.doe@example.com\nAPP_DESCRIPTION=A vulnerable e-commerce application for security testing.\nAPP_KEYWORDS=juice-shop, vulnerable, security, pentest, ctf\nAPP_LICENSE=MIT\n# End of .env file",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.9,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The .env file contains sensitive information that is exposed to the public.",
    "fix_suggestion": "Remove sensitive information from the .env file and store it securely.",
    "business_impact": "Sensitive information is exposed to the public, which could be used to exploit the application.",
    "raw": {
      "url": "https://juice-shop.herokuapp.com/.env",
      "status": 200,
      "path": "/.env"
    }
  }
]
```

```

    "description": "Exposed .env file \u2014 may contain secrets, API keys, and database credentials.",
    "rule_id": "sensitive-path-.env",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /.env \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright (c)
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.5335,
    "risk_category": "HIGH",
    "category_source": "consistency_cache",
    "category_reason": "locked to historical category HIGH",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
    "fix_suggestion": "",
    "business_impact": "The disclosed API keys helps attackers identify attack vectors, reducing the effort
    "raw": {
        "url": "https://juice-shop.herokuapp.com/.env",
        "status": 200,
        "path": "/.env"
    }
},
{
    "id": "f7c4616c-d347-46ef-a001-eaf5087fad24",
    "title": "Cors Misconfiguration in crossdomain.xml:0",
    "file": "https://juice-shop.herokuapp.com/crossdomain.xml",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "CORS_MISCONFIGURATION",
    "description": "crossdomain.xml found \u2014 may allow Flash-based cross-domain requests.",
    "rule_id": "sensitive-path-crossdomain.xml",
    "confidence": 0.85,
    "cwe_id": "CWE-942",
    "cvss_score": null,
    "code_snippet": "GET /crossdomain.xml \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ CO
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.485,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The CORS policy is overly permissive, allowing unauthorized websites to make authent
    "fix_suggestion": "",
    "business_impact": "A malicious website could read API responses on behalf of authenticated users, poten
    "raw": {
        "url": "https://juice-shop.herokuapp.com/crossdomain.xml",
        "status": 200,
        "path": "/crossdomain.xml"
    }
},
{
    "id": "ac46328a-429e-4b64-bc50-b8492aaa697e",
    "title": "Information Disclosure in config:0",
    "file": "https://juice-shop.herokuapp.com/.git/config",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Exposed .git directory \u2014 source code and commit history are publicly accessible.",
    "rule_id": "sensitive-path-.git-config",
    "confidence": 0.85,
    "cwe_id": "CWE-538",
    "cvss_score": null,
    "code_snippet": "GET /.git/config \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyr
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.4462,
    "risk_category": "MEDIUM",

```

```

"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
"fix_suggestion": "",
"business_impact": "The disclosed Git repository metadata and history helps attackers identify attack vectors, reducing the effort",
"raw": {
  "url": "https://juice-shop.herokuapp.com/.git/config",
  "status": 200,
  "path": "/.git/config"
}
},
{
  "id": "f2777fac-3a64-492a-8b1a-2168b0303ab3",
  "title": "Information Disclosure in backup.sql:0",
  "file": "https://juice-shop.herokuapp.com/backup.sql",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Database backup file is publicly accessible \u2014 critical data exposure.",
  "rule_id": "sensitive-path-backup.sql",
  "confidence": 0.85,
  "cwe_id": "CWE-530",
  "cvss_score": null,
  "code_snippet": "GET /backup.sql \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.4462,
  "risk_category": "HIGH",
  "category_source": "consistency_cache",
  "category_reason": "locked to historical category HIGH",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
  "fix_suggestion": "",
  "business_impact": "The disclosed the database helps attackers identify attack vectors, reducing the effort",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/backup.sql",
    "status": 200,
    "path": "/backup.sql"
  }
},
{
  "id": "1abb09ce-74ce-48d5-a7b0-d431acd1a32f",
  "title": "Information Disclosure in :0",
  "file": "https://juice-shop.herokuapp.com/wp-admin/",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "WordPress admin panel is publicly accessible.",
  "rule_id": "sensitive-path-wp-admin",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /wp-admin/ \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.422,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
  "fix_suggestion": "",
  "business_impact": "The disclosed the admin panel helps attackers identify attack vectors, reducing the effort",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/wp-admin/",
    "status": 200,
    "path": "/wp-admin/"
  }
},
},

```

```

{
  "id": "8e2377ad-9b0b-447a-ac22-ef054f84297d",
  "title": "Cors Misconfiguration in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "LOW",
  "vuln_type": "CORS_MISCONFIGURATION",
  "description": "CORS allows all origins (*). While credentials are not included, this may expose public",
  "rule_id": "cors-wildcard",
  "confidence": 0.6,
  "cwe_id": "CWE-942",
  "cvss_score": null,
  "code_snippet": "Access-Control-Allow-Origin: *",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3588,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The CORS policy is overly permissive, allowing unauthorized websites to make authentic",
  "fix_suggestion": "",
  "business_impact": "A malicious website could read API responses on behalf of authenticated users, poten",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/#/",
    "acao": "*"
  }
},
{
  "id": "508506f2-bcaa-4fa3-8f5c-e68766507183",
  "title": "Information Disclosure in server-status:0",
  "file": "https://juice-shop.herokuapp.com/server-status",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Apache server-status page is publicly accessible.",
  "rule_id": "sensitive-path-server-status",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /server-status \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copy",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
  "fix_suggestion": "",
  "business_impact": "The disclosed server configuration details helps attackers identify attack vectors,",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/server-status",
    "status": 200,
    "path": "/server-status"
  }
},
{
  "id": "ae3c0ab2-cb47-424b-aa38-82c7edca28f3",
  "title": "Information Disclosure in phpinfo.php:0",
  "file": "https://juice-shop.herokuapp.com/phpinfo.php",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "PHP info page is publicly accessible \u2014 exposes server configuration details.",
  "rule_id": "sensitive-path-phpinfo.php",
  "confidence": 0.85,
  "cwe_id": "CWE-200",

```

```

"cvss_score": null,
"code_snippet": "GET /phpinfo.php \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright (c) 2014 Heroku Inc. All rights reserved.\n",
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted attacks.",
"fix_suggestion": "",
"business_impact": "The disclosed configuration files helps attackers identify attack vectors, reducing the time to compromise the application.",
"raw": {
  "url": "https://juice-shop.herokuapp.com/phpinfo.php",
  "status": 200,
  "path": "/phpinfo.php"
}
},
{
  "id": "9c8a6880-7df2-447a-92f6-85fa3b96e45e",
  "title": "Information Disclosure in debug:0",
  "file": "https://juice-shop.herokuapp.com/debug",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Debug endpoint is publicly accessible \u2014 may expose sensitive application internals",
  "rule_id": "sensitive-path-debug",
  "confidence": 0.85,
  "cwe_id": "CWE-215",
  "cvss_score": null,
  "code_snippet": "GET /debug \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright (c) 2014 Heroku Inc. All rights reserved.\n",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted attacks.",
  "fix_suggestion": "",
  "business_impact": "The disclosed internal network services helps attackers identify attack vectors, reducing the time to compromise the application.",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/debug",
    "status": 200,
    "path": "/debug"
  }
},
{
  "id": "b6d76c4f-04b7-43cd-8e00-fc3c3349a88d",
  "title": "Information Disclosure in sitemap.xml:0",
  "file": "https://juice-shop.herokuapp.com/sitemap.xml",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "sitemap.xml may reveal internal URL structure.",
  "rule_id": "sensitive-path-sitemap.xml",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /sitemap.xml \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright (c) 2014 Heroku Inc. All rights reserved.\n",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted attacks.",
  "fix_suggestion": "",

```

```

    "business_impact": "The disclosed internal network services helps attackers identify attack vectors, re
    "raw": {
      "url": "https://juice-shop.herokuapp.com/sitemap.xml",
      "status": 200,
      "path": "/sitemap.xml"
    }
  },
  {
    "id": "fc2dcc1d-37e6-43c9-99ae-5b8532ff9592",
    "title": "Information Disclosure in actuator:0",
    "file": "https://juice-shop.herokuapp.com/actuator",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Spring Boot Actuator endpoints are publicly accessible.",
    "rule_id": "sensitive-path-actuator",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /actuator \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
    "fix_suggestion": "",
    "business_impact": "The disclosed server configuration details helps attackers identify attack vectors,
    "raw": {
      "url": "https://juice-shop.herokuapp.com/actuator",
      "status": 200,
      "path": "/actuator"
    }
  },
  {
    "id": "8f6a0273-60bf-4f80-a6bc-fb097891ee19",
    "title": "Information Disclosure in robots.txt:0",
    "file": "https://juice-shop.herokuapp.com/robots.txt",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "robots.txt may reveal hidden paths and sensitive directories.",
    "rule_id": "sensitive-path-robots.txt",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /robots.txt \u2192 HTTP 200\nContent-Length: 28 bytes\nPreview: User-agent: *\nDisa
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "MEDIUM",
    "category_source": "consistency_cache",
    "category_reason": "locked to historical category MEDIUM",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
    "fix_suggestion": "",
    "business_impact": "The disclosed user accounts and personal data helps attackers identify attack vectors
    "raw": {
      "url": "https://juice-shop.herokuapp.com/robots.txt",
      "status": 200,
      "path": "/robots.txt"
    }
  },
  {
    "id": "4a505b6c-b678-4c73-ac92-d8395f3db40a",
    "title": "Information Disclosure in .DS_Store:0",
    "file": "https://juice-shop.herokuapp.com/.DS_Store",

```

```

"line_start": 0,
"line_end": null,
"severity": "MEDIUM",
"vuln_type": "INFORMATION_DISCLOSURE",
"description": "macOS .DS_Store file is publicly accessible \u2014 may reveal directory structure.",
"rule_id": "sensitive-path-.DS_Store",
"confidence": 0.85,
"cwe_id": "CWE-538",
"cvss_score": null,
"code_snippet": "GET /.DS_Store \u2192 HTTP 200\nContent-Length: 9903 bytes\nPreview: <!--\n ~ Copyright
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
"fix_suggestion": "",
"business_impact": "The disclosed server configuration details helps attackers identify attack vectors,
"raw": {
  "url": "https://juice-shop.herokuapp.com/.DS_Store",
  "status": 200,
  "path": "/.DS_Store"
}
},
{
  "id": "677e9018-b4fd-492d-95ee-a3507869c9fd",
  "title": "Missing Security Header in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "MISSING_SECURITY_HEADER",
  "description": "Missing HTTP Strict-Transport-Security (HSTS) header. Without HSTS, browsers may allow
  "rule_id": "header-missing-strict-transport-security",
  "confidence": 0.95,
  "cwe_id": "CWE-319",
  "cvss_score": null,
  "code_snippet": "Response headers: Strict-Transport-Security = (not set)",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3168,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server response is missing recommended HTTP security headers that instruct brows
  "fix_suggestion": "",
  "business_impact": "Without this header, user accounts and personal data is more vulnerable to XSS, cli
  "raw": {
    "url": "https://juice-shop.herokuapp.com/#/",
    "header": "Strict-Transport-Security",
    "check": "missing_header"
  }
},
{
  "id": "14560cea-5378-47fc-862f-1fc9145b7b00",
  "title": "Information Disclosure in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "LOW",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Missing Referrer-Policy header. Sensitive information in URLs may be leaked to third-par
  "rule_id": "header-missing-referrer-policy",
  "confidence": 0.8,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "Response headers: Referrer-Policy = (not set)",
  "sources": [

```

```
    "url-scanner"  
  ],  
  "risk_score": 0.2496,  
  "risk_category": "LOW",  
  "category_source": "score",  
  "category_reason": "score-threshold",  
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted attacks",  
  "fix_suggestion": "",  
  "business_impact": "The disclosed server configuration details helps attackers identify attack vectors, potentially leading to data breaches or service outages.",  
  "raw": {  
    "url": "https://juice-shop.herokuapp.com/#/",  
    "header": "Referrer-Policy",  
    "check": "missing_header"  
  }  
}  
]
```